

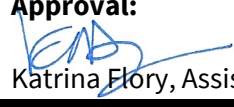


DAS Policy

No:
2100-15

Physical and Environmental Protection

Effective:
March 5, 2024

Approval:

Katrina Flory, Assistant Director/State CIO

I. Purpose

The purpose of this policy is to provide **Physical** and **Environmental** protection (PE) requirements for Ohio Department of Administrative Services (**DAS**)-**managed information systems** and for the facilities in which they operate. Documented PE security controls are needed to ensure information systems are properly protected against Physical and Environmental threats.

The first occurrence of the word in the policy body outside of a title or heading is in bold, italic type, and is hyperlinked to the definition in Section IV. In addition, references to National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, “Security and Privacy Controls for Federal Information Systems and Organizations,” family identifiers and control numbers are provided in parentheses next to requirement headers, where applicable.

II. Scope

The scope of this policy includes any DAS-managed information system and the facility in which it operates. This policy also applies to DAS Data owners, system, and **Service Owners**, and extends to **External Service Providers**.

For the purposes of this policy, ‘facility’ refers primarily to Physical locations containing concentrations of DAS-managed information system resources including, for example, Data centers, server rooms, rooms containing sensitive network, telecommunications, or electrical equipment, and mainframe computer rooms. ‘Managed service partner facility’ refers to these same Physical locations when operated by an external entity through agreement with DAS.

This policy is intended to detail required Physical and Environmental security controls but is not intended to supersede local or state building regulations, or fire or electrical codes.

III. Policy

Each DAS-managed information system and the facility in which it operates shall adhere to the following Physical and Environmental protection requirements.

A. **Physical Access Authorizations (PE-2)**: This control applies to all facilities where DAS-Managed Information Systems operate, including the facilities of External Service Providers. For each facility, the facility manager shall:

1. Develop, and maintain a list of approved individuals with authorized access to the facility.
2. Issue authorization credentials for facility access. Authorization credentials include, for example, badges, identification cards, and smart cards. For each facility, the strength of authorization credentials needed (including level of forge-proof badges, smart cards, or identification cards) shall be commensurate with the results of the **Data** classification as outlined in Ohio Administrative Policy IT-13, "Data Classification," as well as the **System Classification**.
3. Review the access list detailing authorized facility access by individuals at least quarterly or more frequently if required by other regulations.
4. Remove individuals from the facility access list when access is no longer required.
5. Enforce Physical access authorizations to information systems in addition to Physical access controls for sections of the facility where **Federal Tax Information (FTI)** is received, processed, stored, or transmitted or where dictated based on the results of the **Risk Assessment**, conducted in accordance with DAS Policy 2100-08, "Risk Assessment," and Data classification.
6. For information systems subject to the **Federal Bureau of Investigation (FBI) Criminal Justice Information Services (CJIS) Security Policy**, Physical access to locations housing such systems shall be based on role.
7. Unescorted access to FBI CJIS information systems shall be restricted to only those individuals with formal authorizations for the information system. All other individuals requiring access to the information system must be escorted.

B. **Physical Access Control (PE-3)**: This control applies to all facilities where DAS-Managed Information Systems operate, including the facilities of managed system providers. For each facility, the facility manager shall:

1. Enforce Physical access authorizations at entry/exit points by:
 - a) Verifying individual authorizations before granting access to the facility; and
 - b) Controlling ingress/egress to the facility using systems/devices or guards.

2. Maintain Physical access audit logs for entry/exit points.
 3. Provide security safeguards to control access to areas within the facility officially designated as publicly accessible.
 4. Escort visitors and monitor visitor activity.
 5. Secure keys, combinations, card readers and other Physical access devices.
 6. Inventory Physical access devices at least annually.
 7. Change combinations at least annually and when combinations are compromised; or when an individual who knows the combination retires, terminates employment, or transfers.
 8. When a key is lost or stolen, re-key or replace the associated lock.
 9. The facility manager shall ensure regularly scheduled and random Physical security checks occur at the Physical boundary of facilities housing FBI CJIS information systems.
 10. Facilities housing FBI CJIS information systems shall employ guards and/or alarms to monitor every Physical access point to the facility 24 hours per day, 7 days per week.
- C. **Access Control for Transmission Medium (PE-4):** Commensurate with the results of the Risk Assessment and Data classifications for information systems housed at DAS or External Service Provider facilities, Physical access controls shall be implemented for information system distribution or transmission lines. Security safeguards to control Physical access to information system distribution and transmission lines include, for example: locked wiring closets; disconnected or locked spare network jacks; and/or protection of cabling by conduit or cable trays.
- D. **Access Control for Output Devices (PE-5):** Physical access to information system output or output devices shall be controlled to prevent unauthorized individuals from obtaining the output. Monitors, printers, copiers, scanners, fax machines, and audio devices are examples of information system output devices.
- E. **Monitoring Physical Access (PE-6):** Each DAS or External Service Provider facility shall:
1. Monitor Physical access to the facility where the information system resides to detect and respond to Physical security incidents;
 2. Monitor and respond to Physical intrusion alarms and surveillance equipment;
 3. Review Physical access logs for security violations or suspicious activity at least quarterly; and

4. Coordinate results of reviews and investigations with the Office of Information Security and Privacy (OISP) Enterprise Information Security and Privacy Incident Response Team (SIRT).
- F. **Visitor Access Records (PE-8):** Visitor access records shall include name and organization of person visiting, visitor signature, form of identification, date of access, entry and departure times, purpose of visit, and the name and organization of the person visited. Visitor access records are not required for publicly accessible areas. Each DAS or External Service Provider facility shall:
1. Maintain visitor access records for five years; and
 2. Review visitor access records at least quarterly.
- G. **Power Equipment and Cabling (PE-9):** In compliance with applicable building codes and in alignment with Data center industry best practices for the advertised tier level, power equipment and power cabling at DAS or External Service Provider facilities shall be protected from damage and destruction.
- H. **Emergency Shutoff (PE-10):** Each DAS or External Service Provider facility shall implement the following emergency shutoff controls, except where not required by the regulations outlined in NFPA 70; NEC Article 645, Information Technology Equipment:
1. Provide the capability to shut off power to information systems or information system components in emergency situations;
 2. Appropriately place emergency shutoff switches or devices to facilitate safe and easy access for personnel; and
 3. Protect emergency power shutoff capability from unauthorized activation.
- I. **Emergency Power (PE-11):** DAS or External Service Provider facilities shall provide a short-term uninterruptible power supply to facilitate an orderly shutdown of the information system or an uninterrupted transition to long-term alternate power in the event of a primary power loss.
- J. **Emergency Lighting (PE-12):** In accordance with applicable building codes, DAS or External Service Provider facilities shall employ and maintain automatic emergency lighting that activates in the event of a power outage or disruption that covers emergency exits and evacuation routes within the facility.
- K. **Fire Protection (PE-13):** DAS or External Service Provider facilities shall:

1. Employ and maintain fire suppression and detection devices/systems that are supported by an independent energy source; and
 2. Employ and maintain an automatic fire suppression capability for the information system when the facility is not staffed on a continuous basis.
- L. **Temperature and Humidity Controls (PE-14):** DAS or External Service Provider facilities shall:
1. Maintain temperature and humidity levels within the facility in accordance with the optimal operating range of the information system components.
 2. Monitor facility temperature and humidity levels.
- M. **Water Damage Protection (PE-15):** DAS or External Service Provider facilities shall protect information systems and information system components from damage resulting from water leakage by providing master shutoff or isolation valves that are accessible, working properly, and known to appropriate personnel.
- N. **Delivery and Removal (PE-16):** DAS or External Service Provider facilities must authorize, monitor, and control information system components entering and exiting the facility delivery areas and maintain records of them. Each DAS or External Service Provider facility shall define and document an auditable procedure that details the requirements for information system components entering and exiting the facility as well as the handling of Data that may be stored on the components in accordance with Ohio Administrative Policy IT-05, “**Disposal**, Servicing and Transfer of IT Equipment.”
- O. **Alternate Work Site (PE-17):** While commonly distinct from alternative processing sites, alternate work sites may provide readily available alternate locations as part of contingency operations. Alternate work sites may include, for example, government facilities or private residences of employees. DAS or External Service Provider alternate work sites shall:
1. Identify and employ security controls at the alternate work site in accordance with the information system Risk Assessment and Data classification.
 2. Assess, as feasible, the effectiveness of security controls at alternate work sites.
 3. Provide a means for workers at alternate work sites to communicate with information security personnel in case of security incidents or problems.
- P. **Location of Information System Components (PE-18):** DAS or External Service Provider facilities must position information system components within the facility to minimize potential damage from Physical and Environmental hazards (e.g., locating components in core areas of the facility, choosing places within the facility that emergency crews can access,

avoiding proximity to water sources and exposure to Environmental conditions), and to minimize the opportunity for unauthorized access.

Risk mitigation strategies for facilities housing FBI CJIS information systems must account for Physical and Environmental hazards to the facility itself.

- Q. **FBI CJIS and Ohio LEADS Physical Protection Requirements:** DAS system or Service Owners with systems or **Services** which, as the result of Data classification, Risk Assessment, agency agreement or some other method, have been identified as processing, storing, and/or transmitting Data subject to the FBI Criminal Justice Information Services (FBI CJIS) Security Policy and/or the Ohio Department of Public Safety Law Enforcement Automated Data System (Ohio LEADS) Security Policy shall ensure compliance with the Physical protection requirements outlined therein.
- R. **Procedures:** As of the original effective date of this policy (12/22/2017), any External Service Provider contractual agreements, that involve the use of facilities to house or operate DAS-Managed Information Systems, shall include a requirement to comply with this policy.

IV. Definitions

- A. Availability. Ensuring timely and reliable access to and use of information.¹
- B. Confidentiality. Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.²
- C. Criminal Justice Information (CJI). Criminal Justice Information (CJI) is the abstract term used to refer to all of the FBI Criminal Justice Information Services (CJIS) provided Data necessary for law enforcement agencies to perform their mission and enforce the laws, including but not limited to: biometric, identity history, person, organization, property (when accompanied by any **Personally Identifiable Information**), and case/incident history Data. In addition, CJI refers to the FBI CJIS-provided Data necessary for civil agencies to perform their mission; including, but not limited to Data used to make hiring decisions. The following type of Data are exempt from the protection levels required for CJI: transaction control type numbers (e.g., originating identifying number (ORI), national identification number (NIC), universal control

¹ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013
<<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

² *Ibid.*

number (UCN), etc.) when not accompanied by information that reveals CJI or Personally Identifiable Information.³

- D. DAS-Managed Information Systems. A discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information.⁴ For the purposes of this policy, primary responsibility for managing these systems may be assigned to DAS OIT personnel or other outside entities.
- E. Data. Coded representation of quantities, objects, and actions. The word, “Data,” is often used interchangeably with the word, “information,” in common usage and in this policy.
- F. Disposal. The final transfer of ownership or custody of an information technology device.
- G. Environmental. Aggregate of external procedures, conditions, and objects affecting the development, operation, and maintenance of an information system.⁵ Environmental controls include, for example, fire suppression and detection devices/systems, sprinkler systems, handheld fire extinguishers, fixed fire hoses, smoke detectors, temperature/humidity, HVAC, and power within the facility.⁶
- H. External Service Provider. An entity outside State of Ohio government that provides external information system or service capabilities to DAS by contract.
- I. Federal Bureau of Investigation (FBI) Criminal Justice Information Services (CJIS) Security Policy. The essential premise of the CJIS Security Policy is to provide appropriate controls to protect the full lifecycle of **Criminal Justice Information (CJI)**, whether at rest or in transit. The CJIS Security Policy provides guidance for the creation, viewing, modification, transmission, dissemination, storage, and destruction of CJI. The policy applies to every individual—contractor, private entity, noncriminal justice agency representative, or member of a criminal justice entity—with access to, or who operate in support of, criminal justice Services and information.⁷
- J. Federal Tax Information (FTI). Federal Tax Information (FTI) consists of federal tax returns and return information (and information derived from it) that is in the agency’s possession or

³ “Criminal Justice Information Services (CJIS) Security Policy, Version 5.9,” U.S. Department of Justice, Federal Bureau of Investigation, Criminal Justice Information Services Division, 1 June 2019 <<https://www.fbi.gov/services/cjis/cjis-security-policy-resource-center>>.

⁴ “Criminal Justice Information Services (CJIS) Security Policy, Version 5.9,” U.S. Department of Justice, Federal Bureau of Investigation, Criminal Justice Information Services Division, 1 June 2019 <<https://www.fbi.gov/services/cjis/cjis-security-policy-resource-center>>.

⁵ “FIPS 200, Minimum Security Requirements for Federal Information and Information Systems.” U.S. Department of Commerce National Institute of Standards and Technology, March 2006. <<https://csrc.nist.gov/csrc/media/publications/fips/200/final/documents/fips-200-final-march.pdf>>.

⁶ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

⁷ “Criminal Justice Information Services (CJIS) Security Policy, Version 5.9,” U.S. Department of Justice, Federal Bureau of Investigation, Criminal Justice Information Services Division, 1 June 2019 <<https://www.fbi.gov/services/cjis/cjis-security-policy-resource-center>>.

control which is covered by the Confidentiality protections of the IRC and subject to the IRC 6103(p)(4) safeguarding requirements including IRS oversight. FTI is categorized as Sensitive but Unclassified information and may contain Personally Identifiable Information (PII). FTI includes return or return information received directly from the IRS or obtained through an authorized secondary source, such as Social Security Administration (SSA), Federal Office of Child Support Enforcement (OCSE), Bureau of the Fiscal Service (BFS), or Centers for Medicare and Medicaid Services (CMS), or another entity acting on behalf of the IRS pursuant to an IRC 6103(p)(2)(B) Agreement. FTI includes any information created by the recipient that is derived from federal return or return information received from the IRS or obtained through a secondary source.⁸

- K. Integrity. Guarding against improper information modification or destruction, and includes ensuring information non-repudiation and authenticity.⁹
- L. Personally Identifiable Information. “Personally Identifiable Information” is information that can be used directly or in combination with other information to identify a particular individual. It includes:
 - 1. a name, identifying number, symbol, or other identifier assigned to a person,
 - 2. any information that describes anything about a person,
 - 3. any information that indicates actions done by or to a person,
 - 4. any information that indicates that a person possesses certain personal characteristics.¹⁰
- M. Physical. Security controls that address elements such as Physical access authorizations, transmission mediums, output devices, monitoring, visitor control, visitor access, and alternate work sites. Physical security controls include, for example, Physical access control devices, Physical intrusion alarms, monitoring/surveillance equipment, and security guards (deployment and operating procedures).¹¹
- N. Risk Assessment. The process of identifying, prioritizing, and estimating risks to organizational operations (including mission, functions, image, and reputation), organizational assets, individuals, other organizations, and the Nation, resulting from the operation of an information system.¹²

⁸ “Publication 1075 Tax Information Security Guidelines for Federal, State and Local Agencies, Safeguards for Protecting Federal Tax Returns and Return Information,” Internal Revenue Service, September 2016 <<https://www.irs.gov/pub/irs-pdf/p1075.pdf>>.

⁹ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

¹⁰ Based on Ohio Revised Code Section 1347.01 (E).

¹¹ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

¹² “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

- O. Services. The application of business and technical expertise to enable organizations in the creation, management, and optimization of or access to information and business processes.
- P. System Classification. Refers to the process of assessing the potential impact to **Confidentiality, Integrity, and Availability** of the evaluated system. NIST SP 800-53 refers to Federal Information Processing Standards (FIPS)-199, which is the federal guideline for assessing and classifying information systems.
- Q. Service Owner. A Service Owner is responsible for the delivery (design, performance, integration), continual improvement and management of assigned IT Services.

V. Authority

ORC 125.18

VI. Resources

Document Name	Location
IRS Publication 1075 Tax Information Security Guidelines for Federal, State and Local Agencies	https://www.irs.gov/pub/irs-pdf/p1075.pdf
Federal Bureau of Investigation (FBI) Criminal Justice Information System (CJIS) Security Policy	https://www.fbi.gov/file-repository/cjis_security_policy_v5-9-1_20221001.pdf/view
Ohio Department of Public Safety Law Enforcement Automated Data System (Ohio LEADS) Security Policy	https://leads.ohio.gov/Manuals
National Fire Protection Association (NFPA) 70; National Electric Code (NEC)	https://www.nfpa.org/nec/
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
Ohio IT Standard ITS-SEC-02 Security Controls Framework	https://das.ohio.gov/technology-and-strategy/policies
Ohio Administrative Policy IT-05 Disposal, Servicing and Transfer of IT Equipment	https://das.ohio.gov/technology-and-strategy/policies
Ohio Administrative Policy IT-13 Data Classification	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 2100-08 Risk Assessment	https://das.ohio.gov/technology-and-strategy/policies

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor
Columbus, Ohio 43215

614-644-6860 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
12/22/2017	Original Policy.
08/12/2021	Added a requirement related to FBI CJIS and Ohio LEADS Physical protection requirements. Updated the compliance language in the policy due to the amount of time the policy has been in effect. Also, updated the references, definitions and branding in the policy.
03/05/2024	Updated the policy template. Added a revision history review frequency statement.